CYBERSECURITY TABLETOP EXERCISE

EXAMPLE SCENARIOS

- https://twitter.com/badthingsdaily
- https://www.cisa.gov/resources-tools/services/cisa-tabletop-exercise-packages

GENERAL DISCUSSION QUESTIONS

- 1. What are the greatest cyber threats to your organization?
- 2. What information technology (IT) systems or processes are the most critical to your organization?
- 3. What cybersecurity threat information does your organization receive?

  a. What cyber threat information is most useful?

  b. How is information disseminated across your organization and by whom?

  c. What actions would your organization take following an alert like the one presented in the scenario?

GENERAL DISCUSSION QUESTIONS

- 4. Has your organization conducted a risk assessment to identify specific cyber threats, vulnerabilities, and critical assets?

  a. What information technology (IT) systems or processes are the most critical to your organization?

  b. Describe your organization's asset management plan and how you prioritize critical assets.

  c. What improvements have been implemented to enhance cyber resilience following recent risk assessments?

  d. Does your organization have a vulnerability management program dedicated to mitigating known exploited vulnerabilities in internet-facing systems?

GENERAL DISCUSSION QUESTIONS

- 5. Does your organization have backups of vital records stored in a location separate from your primary working files/copies?
  - a. *How frequently do you run backups?*
  - b. *How long do you keep copies of archived files backed up?*
  - c. *How long would it take to restore primary files from backups?*
- 6. Discuss your risk management strategy.
  - a. *How is it developed/maintained?*
  - b. *Does your organization apply Zero Trust Architecture (ZTA)/zero-trust concepts?*
  - c. *What considerations are addressed in your risk management strategy (e.g., extended downtime, impaired functionality, loss of data, etc.)?*

GENERAL DISCUSSION QUESTIONS

- 7. Describe your organization's cybersecurity training program for employees.
  - a. *How often are employees required to complete this training?*
  - b. *Is training required during employee onboarding before granting system/network access?*
  - c. *What additional training is required for employees who have system administrator-level privileges?*
  - d. *What type of training methods or approaches have you found most beneficial?*
- 8. How do employees report suspected phishing attempts or other possible cybersecurity incidents?
  - a. *What actions does the IT department take when suspicious emails are reported?*
  - b. *What feedback do employees receive after reporting a suspicious email or event?*

DAY 1

The Cybersecurity and Infrastructure Security Agency (CISA) issues an Alert regarding a new ransomware variant. This ransomware is being used in a campaign targeting state, local, tribal, and territorial governments, as well as private sector firms.

DAY 4

- Members of your Finance department receive an email that appears to be from the CFO. It instructs them to access a PDF containing details about an unpaid bill from a third-party vendor supporting your organization. Several employees call the CFO to verify the email's authenticity. She replies that she did not send it, and that there is no outstanding vendor bill. Nevertheless, some employees still open the PDF.

LOCKBIT 2.0

ALL YOUR IMPORTANT FILES ARE STOLEN AND ENCRYPTED!

All your files stolen and encrypted
for more information see
RESTORE-MY-FILES.TXT
that is located in every encrypted folder.

Would you like to earn millions of dollars?
Our company acquire access to networks of various companies, as well as insider information that can help you steal the most valuable data of any company.
You can provide us accounting data for the access to any company, for example, login and password to RDP, VPN, corporate email, etc.
Open our letter at your email. Launch the provided virus on any computer in your company.
Companies pay us the foreclosure for the decryption of files and prevention of data leak.
You can communicate with us through the Tox messenger
https://tox.chat/download.html
Using Tox messenger, we will never know your real name, it means your privacy is guaranteed.
If you want to contact us, use ToxID:
3085889A0C515D2FB124D645906F5D3DA5CB97CE8EA975959AE4F95302A04E1D709C3C4AE9B7
If this contact is expired, and we do not respond you, look for the relevant contact data on our website via Tor or Brave Browser
http://lockbitapt6vx57t3eeqjofwgcglmutr3a35nygvokja5uuccip4ykyd.onion

WHAT DO YOU DO FIRST?

WHO DO YOU REPORT THIS TO AND HOW?

FROM A TECHNICAL PERSPECTIVE, WHAT ACTIONS DO YOU TAKE TO STOP/SLOW THE PROBLEM?

WHAT TEAMS NEED TO BE INVOLVED OR "STOOD UP"?

DO NOTIFY OUR EMPLOYEES THAT AREN'T INVOLVED?

DO WE NOTIFY OUR CLIENTS?
IF SO, HOW LONG UNTIL WE DO THAT?
IF SO, HOW IS THAT DONE AND WHO DOES THE COMMUNICATION?

DO WE PAY?

WHAT HAPPENS IN THE “LONG-TERM”?

RESOURCES

- *Devin Shelley's talk at SAINTCON*
- *The CISA Ransomware CTEP Manual*